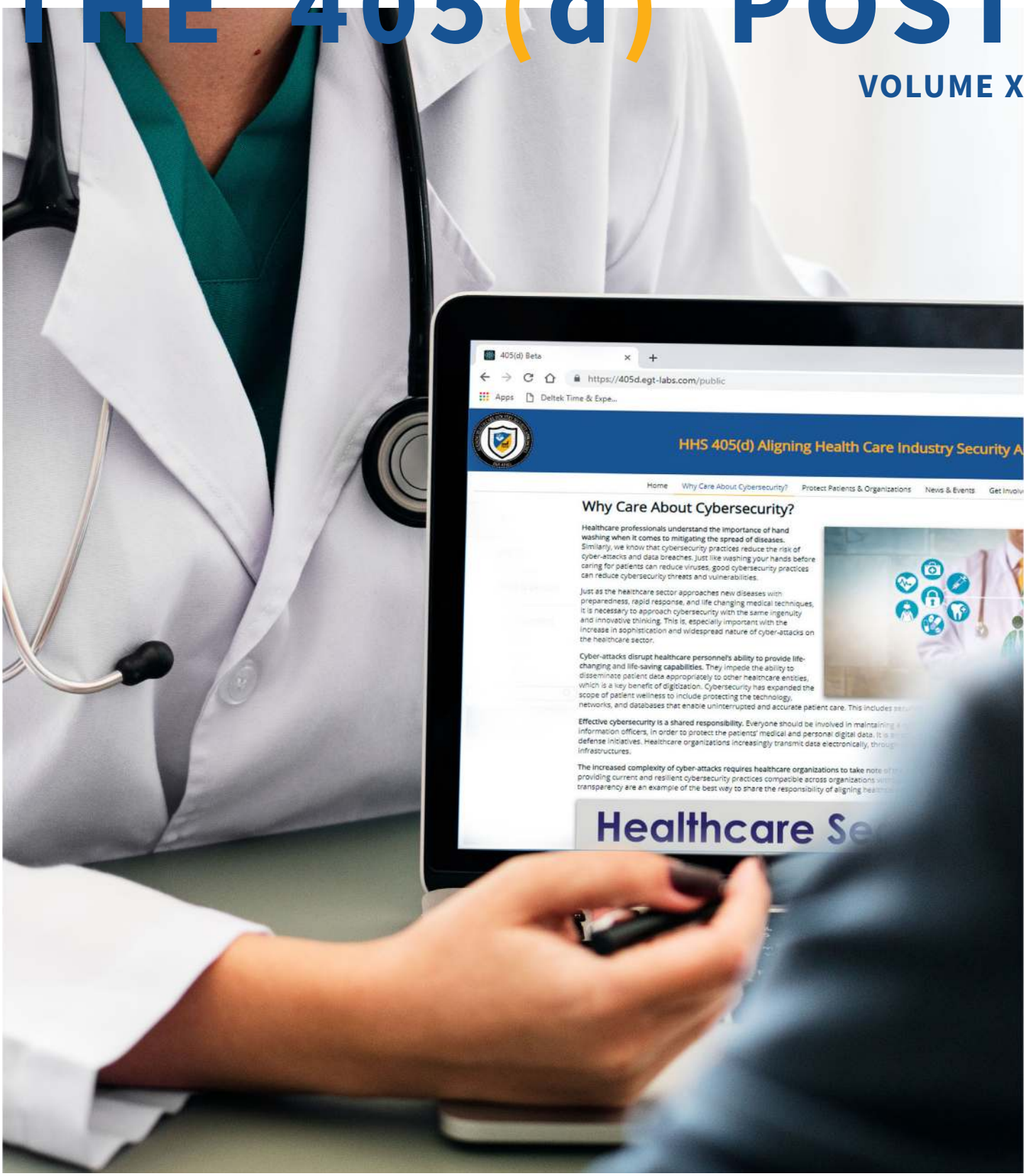
THE 405(d) POST

VOLUME X



HHS 405(d)
Aligning Health Care
Industry Security Approaches

Cybersecurity is Not an IT Issue

Why it takes more than technology to defend your organization

By J. David Sims, 405(d) Task Group Member

"Dr. Cooper, the computers aren't working right. They all have a message on the screen about paying to have our data and systems unlocked!"

This was the welcome that Dr. Cooper received on Monday morning from his panicked practice manager, Sherry, as he walked into his practice. No, this would not be a good morning, not at all.

"Sherry, get IT on the phone!" shouted Dr. Cooper as he made his way to every computer and was met with the same ransomware message on each screen. Dr. Cooper had invested a modest amount of money each month to outsource his IT support and security to a local IT firm.

"The IT guys said they can't log in remotely, so they'll have to send someone out. It will be an hour or so before anyone can get here." Sherry explained.

In the meantime, patients were starting to fill the lobby for their morning appointments. With no plan of how to respond to such an incident, Sherry instructed her staff to start rescheduling patients and prepared to close the office for the rest of the day. A little while later, Scott from their IT firm arrived. He instantly realized he was walking into a mess. As he walked through the parking lot, he could hear agitated patients complaining about having to reschedule. Upon entry he noticed another patient expressing concern about their medical records as the front desk person explained that they are experiencing a ransomware attack. Scott quickly assessed the situation and realized that there was nothing he can do to resolve this. Scott turned to Dr. Cooper with a look of dread and began rapidly firing questions:

"Do you have a ransomware response plan?"

"Do you have cyber insurance?"

"Who is handling public relations?"

"Have you called your attorney?"

Dr. Cooper threw up his hands and said, **"Wait. So, you're telling me that you can't fix this?"**

Scott replied, **"You have an active ransomware attack happening. Likely, this is going to be a data breach. If so, you are going to have to notify all your patients that have been affected. You may also have to notify the State and HHS and follow State and Federal breach laws. You'll also need to determine if the media will need to be notified."**

"How could this happen?! We pay you for security!" exclaimed Dr. Cooper, who was sitting down with his head in his hands as he pondered what this will mean for his practice and his patients.

We will leave this true story now and look closer at the question Dr. Cooper asked, **"How could this happen?"** Afterall, they are indeed paying for cybersecurity and the IT firm is providing good security. So, how then, can this happen?

Like many businesses, this practice did not understand that cybersecurity is not just a function of IT. In fact, there are three areas that must be present for an effective privacy and security program to work.

Let's take a closer look at these three areas.

People

Social engineering, or hacking humans as it is sometimes called, is today's most successful way to attack an organization. The attacker can bypass all the security that keeps them out if they are able to have someone on the inside let them in. Technology has no way of keeping out the bad guys if the good guys are letting them in through the "employee entrance".

Your people will either be a security asset or a security liability. Mostly, people want to do what is right. They want to protect the patients and their employers, but they are often not given the proper tools or training to make them effective security assets.

Organizations should dedicate time and resources to effectively train and test their employees on proper cyber hygiene, privacy and security topics, and incident response.

Remember, it's the people, people.

Processes

A process is the guide that explains to employees how your business does certain things. All too often, a business will either not have processes in place, or they do have them, but nobody knows what they are because they are not trained on them.

It is a guarantee that if your organization has never practiced an incident response, even a table-top exercise, your team will do nearly everything wrong when an actual incident occurs.

Not having an effective, planned response will cost you much more when (not if) disaster strikes. "Failing to plan is planning to fail," as Ben Franklin said.

Technology

This is the final piece of the cybersecurity trifecta, and yet most people think it is the only piece. This is also the most confusing piece due to its complexity and many other factors.

Following a framework or guide, like HICP (Health Industry Cybersecurity Practices), will help organizations understand where their focus should be to properly address the most common threats.

Ensure you are devoting enough resources to this area, but understand that technology alone will not properly protect you.

Conclusion

People, processes, *and* technology. Those are the three areas that must thrive for any organization to have an effective privacy and security program. A cyber incident can happen at a moment's notice. How well you can recover from it will depend on how prepared you are in advance. In a crisis, people do not rise to the occasion. They fall to their level of preparation. A resource that can definitely get you started and begin to protect your patients from cyber threats is the *Health Industry Cybersecurity Practices: Managing Threats and Protection Patients* publication located here. This publication lays out the top five threats facing the healthcare industry and provides the top 10 practices needed to mitigate them. If you do not have your IT department in house but use a third party, this is a document you can provide to your IT contractor and ask- "Are you doing these things? And if not, why?" Protecting patients is our number one priority and we all now have to realize that this includes cyber, and using the most up to date practices is paramount to achieving this goal.

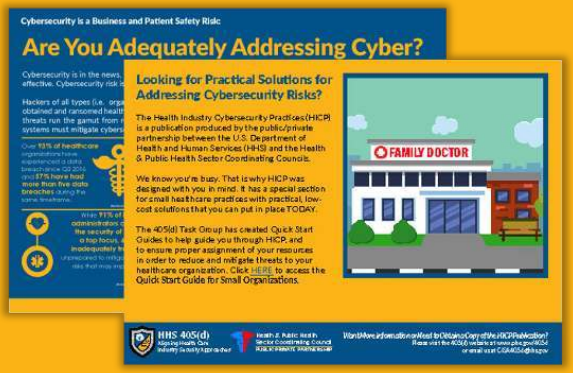
405(d) HICP in the Spotlight

New 405(d) Resources

In 2021 the 405(d) Program has grown its reach and continues to pursue its mission of Aligning Healthcare Industry Security Approaches. The 405(d) Program is now able to assist in many of your cybersecurity needs. Whether it is instituting cybersecurity practices using HICP, or educating your staff on cybersecurity, we are here for you! Check out the list below of our new resources released in 2021 that can assist you in your goal to continue to protect your patients from cyber threats!

405(d) Executive Cards

The 405(d) Task Group has officially created new 405(d) Small and Medium/Large Executive Cards! These executive cards provide a snapshot of why executives at both small and medium/large organizations need to start thinking about cyber safety as patient safety and provide a place to start that is pulled directly from the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients (HICP) publication. Check them out and jump start your cybersecurity protection today! To download each card, click the links below!



Small Organization Executive Card

Medium/Large Organization Executive Card

405(d) Five Threat Flyers

The 405(d) Task Group has officially created new 405(d) Five Threat Flyers! Each of these flyers details one of the five threats and top mitigating practices you can implement to protect your organization. All of the information on the flyers was pulled directly from the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients (HICP) publication. Check them out and jump start your cybersecurity protection today! To download each flyer, click the links below!

- Email Phishing
- Ransomware
- Loss or Theft of Equipment or Data
- Insider, Accidental or Intentional Data Loss
- Attacks on Connected Medical Devices

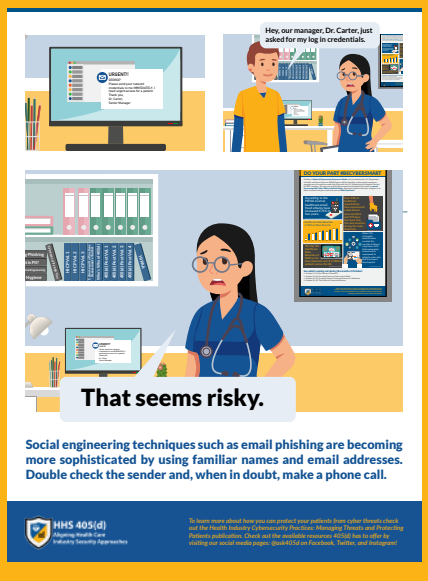
Myth vs. Fact Campaign

The Myth Vs. Fact initiative is an engaging animated effort which allows the 405(d) Program to highlight the many myths that exist within cybersecurity and proven facts to increase general cybersecurity awareness. Check them out on our social media pages: LinkedIn, Facebook, Twitter, Instagram at **@ask405d.**

That Seems Risky Campaign

The That Seems Risky initiative is an effort to highlight common cyber criminal tactics that the HPH sector should be aware of and highlight preventative tips for the future. See below for our most recent posters!

- March—That Seems Risky (Patient Safety)
- April—That Seems Risky (Social Engineering)



405(d) Chronicles

By Amy Wood, 405(d) Task Group member

The 405(d) Chronicles is a platform for sharing firsthand insight, lessons learned, and perspectives from cybersecurity professionals in the field today.

This past year has been challenging, and that is putting it nicely. While it's easy to blame the pandemic for poor security and inadequate vendor choices, the reality is that the behaviors of small practices and the vendors they use were bordering on dangerous prior to the pandemic. Stress, fear, and uncertainty only exacerbated these behaviors. Just look at how people behaved with toilet paper! It's no wonder they've made business decisions without considering the potential risks and consequences associated with those decisions.

Let me tell you a short story; it may resonate with you. I had a conversation with one of my dental clients a few weeks prior to the shutdown about a Voice over Internet Protocol (VoIP) provider that integrates with the Electronic Medical Record (EMR). The doctor and I discussed how this vendor claimed to be Health Insurance Portability and Accountability Act (HIPAA) compliant but wouldn't answer any questions about *how* they believed they were compliant. We agreed not to pursue engagement with that VoIP provider. Fast forward ten weeks and we are nearing reopening after shelter-in-place orders. The same doctor got a call from an overeager sales rep from the same VoIP provider and said *just enough* to convince the doctor to deviate from the vendor vetting process we had utilized for several years. Not only did they have terrible implementation and support from the vendor, but the practice almost allowed the VoIP provider to piggyback on an admin-level user within the EMR. Without the watchful eye of IT, who did not deviate from their protocols, this could have been a disaster. Unfortunately, this is not an isolated incident.

While the practices were overwhelmed and made bad choices, the vendors that these practices turned to for help with their new workload grappled with their own issues of providing solutions as quickly as possible. These included solutions for paperless forms, touchless payments, and telehealth. These were all available globally but were not currently being used in the dental sector and were not generally provided by these vendors. Everyone was flying by the seat of their pants and hoping they were doing it right.

Now here we are, a year later, and virtual consults are still being done on an ongoing basis using FaceTime or free Zoom, even though it should be used on a one-off emergency basis. Sadly, once a system is implemented incorrectly, it is difficult, if not impossible, to get staff to adopt change without forcing it and damaging the relationship.

Don't even get me started on the compliance or security of these third-party vendors. Half of them can't even spell HIPAA correctly - two P's, two A's, or a new one I got this week was two I's. It doesn't instill a high degree of confidence if they can't spell the word in which they claim to be compliant.

While these vendors created services to fill a void, and some of them are incredibly useful, security and compliance are usually considered after the fact, especially in the small sector. Unfortunately, most small practices, especially those in the fringes of healthcare such as dentists and chiropractors, have antiquated, specialized EMRs. They are typically not secured at the data source but instead rely on IT providers to augment security, including encryption. The point here is to be vigilant and don't allow any external force (natural disaster, pandemic, or overeager salesperson) to speed up the vetting plan you have in place. It's there for a reason, especially in dire situations, it is the protection when those less-than-stellar choices try to rear their ugly heads.

This is a tough job! It's tempting to think about walking away from the small practices in favor of larger healthcare entities with larger budgets. Fortunately, there are those of us that specialize in these smaller practices to keep electronic protected health information (ePHI) safe on their behalf.

Happening Around Us

Accidental Data Breach Reported by Wyoming Health Dept.

At the end of April, the Wyoming Department of Health (WDH) announced a mistaken exposure of laboratory test result data involving the health information of thousands of Wyoming residents and others. The department became aware of a breach involving protected health information on March 10, 2021. It was discovered a workforce member inappropriately handled the health information of approximately 164,021 Wyoming residents and others as early as November 5, 2020. The incident involved unintentional exposure of 53 files containing COVID-19 and influenza test result data and one file containing breath alcohol test results. These files were mistakenly uploaded by a WDH Public Health Division workforce member to private and public online storage locations, known as repositories, on servers belonging to GitHub.com. WDH started sending notices to potentially affected individuals around April 26, however, contact information was unfortunately incomplete for many others.

Looking for mitigation tactics to prevent accidental data breach within your healthcare organization? Check out the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients publication.

Click here to read the full article on Wyoming Department of Health's website.

Healthcare's Biggest Cybersecurity Blind Spots and Misconceptions

HealthITSecurity reports that threat actors are moving at a drastic pace and with stealthy tactics able to hide their activities from system administrators. The truth is that healthcare is struggling with some massive cybersecurity blindspots and misconceptions, making it extremely difficult to keep pace. Data exfiltration and extortion was once seen as a rare worst-case scenario, but now it's occurring in the majority of ransomware attacks. Meanwhile, reports show an increasing number of attacks targeting a range of newly disclosed vulnerabilities, along with legacy security gaps that administrators have overlooked and failed to patch. Though the tides have somewhat shifted, and it appears most understand that the threat is real and data breaches are nearly inevitable, what's holding back the sector from a more effective defense strategy? For Mitch Parker, Indiana University Health's executive director of information services, the three major gaps not being addressed in healthcare are supply chain security, organizational integration, and physical security. According to Parker, it's not enough to tackle just one element, like EHR, API, or application security and think the task is done. Instead, providers should examine the complete list of customer needs, then develop a plan to address those areas.

Click here to read the full article at HealthITSecurity.

CISA Alert

Vulnerabilities found in Ivanti Pulse Connect Secure products

The Cybersecurity and Infrastructure Security Agency (CISA) released an alert of compromises affecting U.S. government agencies, critical infrastructure entities, and other private sector organizations by a cyber threat actor—or actors—beginning in June 2020 or earlier related to vulnerabilities in certain Ivanti Pulse Connect Secure products. Since March 31, 2021, CISA assisted multiple entities whose vulnerable Pulse Connect Secure products have been exploited by a cyber threat actor. The threat actor is using this access to place webshells on the Pulse Connect Secure appliance for further access and persistence. The known webshells allow for a variety of functions, including authentication bypass, multi-factor authentication bypass, password logging, and persistence through patching.

Click here to view the CISA alert.

Other Federal Resources

CISA

- Resilience Series Graphic Novel: Bug Bytes
- Defending Against Software Supply Chain Attacks
- COVID-19 Checklist: Securing Your Business and Clinical IT
- Multi-Factor Authentication (MFA)
- Cost of a Cyber Incident: Systematic Review and Cross-Validation
- CISA 2020 Year in Review
- SolarWinds and AD-M365 Compromise Risk Decisions for Leaders

HC3

- HPH Cyber Supply Chain Risk Management (C-SCRM)
- North Korean Cyber Activity
- 2021 Forecast: The Next Year of Healthcare Cybersecurity
- Tools for Detection of Compromise of Microsoft Exchange Server Vulnerabilities
- Application Programming Interfaces and Healthcare Cybersecurity
- Active Exploitation of Pulse Secure Zero-Day Vulnerabilities by Multiple Threat Actors
- Vishing and Phishing Campaigns Targeting the HPH Sector

Upcoming Events

- June Spotlight Webinar
- 405(d) Spring Campaign! Keep a look out for the 405(d) Program's newest resources called **"Myth vs. Fact"** and **"That Seems Risky."**

Follow us!

Facebook

Instagram

Twitter

LinkedIn

And check out our website at 405d.hhs.gov!

About The 405(d) Post

This newsletter is for information purposes only and aims to broaden awareness and align healthcare security approaches. The news articles represented in this newsletter are chosen at random to foster awareness and are not in promotion of any news organization. The "A Word from the Task Group" and the "405(d) Chronicles" is written by a different 405(d) Task Group Member each issue and does not reflect the views of HHS as a whole. All Task Group Members have been invited to contribute to this newsletter.

Need To Contact Us? Email us at cisa405d@hhs.gov